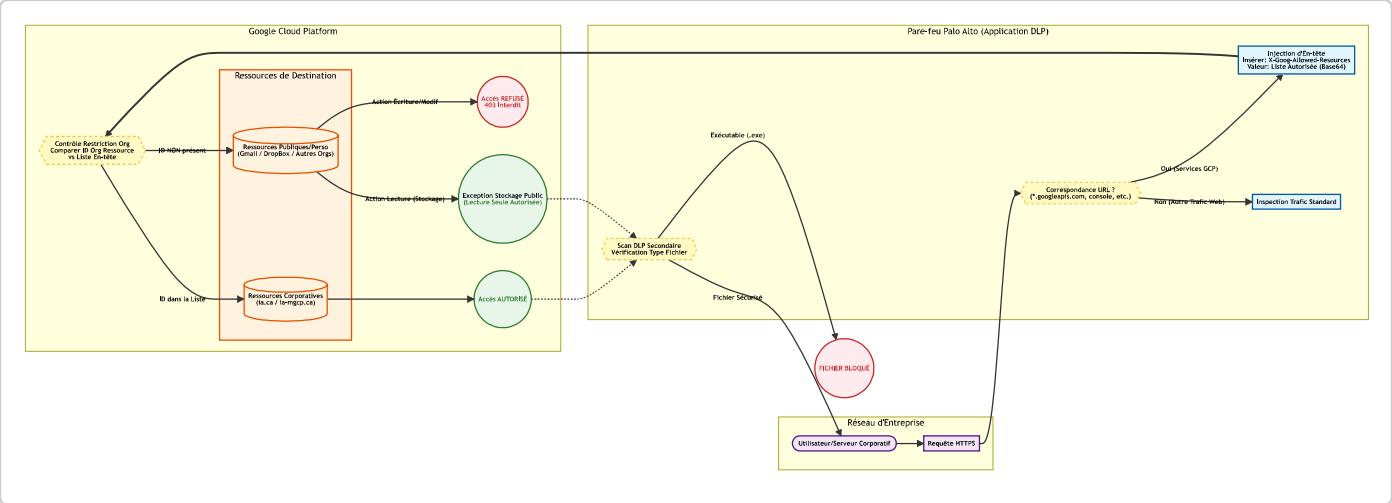
Services GCP autorisés via la restriction d'organisation

Objectif

- Autoriser le transfert de données via le réseau depuis le périmètre corporatif (Prisma) vers les actifs GCP qui font partis des organisations de confiance.
- Empêcher l'exfiltration de données via le réseau depuis le périmètre corporatif (Prisma) vers les actifs GCP qui ne font pas partis des organisations de confiance.

Solution à haut niveau

1. **Interception du trafic:** Palo Alto intercepte, décrypte et inspecte le trafic HTTPS à destination des services Google Cloud. Cette pratique requiert que les charges de travail clientes qui communiquent avec les services Google Cloud, doivent faire confiance au certificat racine IAFG (http://aia.pki.iafg.net/iAFGRootCA.crt) afin de maintenir l'intégrité de la chaine d'encryption et éviter les erreurs TLS. Pour plus de détails sur les certificats privés iA, veuillez vous référer à Venafi (https://connect.ia.iafg.net/docs/default/system/venafi/en/introduction-templates/).
2. **Injection d'en-tête:** Le pare-feu injecte l'en-tête HTTP `X-Goog-Allowed-Resources` contenant une liste des identifiants d'organisations autorisées.
3. **Application (côté Google):** Google compare l'identifiant d'organisation de la ressource demandée avec l'en-tête.
    - **Correspondance:** Accès autorisé.
    - **Pas de Correspondance:** Google refuse la demande.



Détails d'implémentation

A. Filtrage URL et catégorisation (Palo Alto)

Pour appliquer l'injection d'en-tête spécifiquement au trafic GCP sans interrompre l'accès à la console Google Cloud, une **Catégorie d'URL** personnalisée nommée `URL_GCP_Tenant_Restriction` a été créée contenant les domaines suivants:

- **API Principales (CLI/SDK):** liste des services sous le domaine `googleapis.com` qui supportent la restriction d'organisation (couvre les services documentés ici (https://docs.cloud.google.com/resource-manager/docs/organization-policy/restricting-resources-supported-services)).
- **Points de terminaison régionaux spécifiques à Vertex AI:** `northamerica-northeast1-aiplatform.googleapis.com`, `northamerica-northeast2-aiplatform.googleapis.com`, `southamerica-east1-aiplatform.googleapis.com`, `southamerica-west1-aiplatform.googleapis.com`, `us-central1-aiplatform.googleapis.com`, `us-east1-aiplatform.googleapis.com`, `us-east4-aiplatform.googleapis.com`, `us-south1-aiplatform.googleapis.com`, `us-west1-aiplatform.googleapis.com`, `us-west2-aiplatform.googleapis.com`, `us-west3-aiplatform.googleapis.com`, `us-west4-aiplatform.googleapis.com`, `us-east5-aiplatform.googleapis.com`
- **Arrière plan de la console Google Cloud:** `clients6.google.com` (sous-domaine utilisé par plusieurs services Google pour les communications client. Les points de terminaison sous ce sous-domaine sont non documentés et sont requis pour les opérations de l'interface utilisateur de la consol Google Cloud).
- **Console et authentification:** `cloud.google.com`, `googleusercontent.com`.
- **Points de terminaison de services:** `gcr.io`, `pkg.dev`, `cloudfunctions.net`, `run.app`, `tunnel.cloudproxy.app`, `datafusion.googleusercontent.com`.

B. Configuration de l'injection d'en-tête

Un **profil de filtrage URL** est appliqué au trafic correspondant aux catégories ci-dessus pour injecter l'en-tête HTTP suivant:

- **Nom de l'en-tête:** `X-Goog-Allowed-Resources`
- **Valeur injectée (encodée en Base64):**


```
eyJyZXNvdXJjZXMiOiBbIm9yZ2FuaXphdGlvbnMvNDU3NDY0Mjk3MTQiLCAib3JnYW5pemF0aW9ucy80MzM2MzczMzg1ODkiLCAib3JnYW5pemF0aW9ucy82MDQ4OTA4MzkzNjEiXSwgIm9wdGlvbnMiOiAiY2xvdWRTdG9yYWdlUmVhZEFsbG93ZWQifQ==
```


C. Valeur injecté non encodée

La valeur non encodée, injectée dans l'en-tête HTTP se présente sous la forme du format JSON suivant:

```
{
  "resources": [
    "organizations/45746429714",
    "organizations/433637338589",
    "organizations/604890839361"
  ],
  "options": "cloudStorageReadAllowed"
}
```

Correspondance des identifiants d'organisation:

- `45746429714` : **ia-mgcp.ca** (organisation corporative iA)
- `604890839361` : **ia.ca** (organisation corporative iA)
- `433637338589` : **Organisation publique appartenant à Google** (requise pour les ressources partagées standard de Google)

Exceptions de sécurité et atténuation des risques

Exception de lecture Cloud Storage

- **Configuration:** L'option `"cloudStorageReadAllowed"` est activée dans l'en-tête.
- **But:** Cela permet aux utilisateurs de lire/télécharger des fichiers depuis **n'importe quel** bucket Google Cloud Storage (même en dehors des organisations autorisées). Ceci est nécessaire pour éviter de bloquer l'accès légitime aux actifs publics (ex: images, jeux de données publics, dépôts de logiciels) hébergés sur GCP.

Atténuation des risques (blocage de fichiers)

Pour atténuer le risque de téléchargement de fichiers malveillants introduit par l'exception `cloudStorageReadAllowed` :

- **Analyse secondaire:** Une règle de sécurité Palo Alto distincte analyse tous les fichiers téléchargés depuis les Cloud Storage bucket.
- **Action:** Les types de fichiers à haut risque (comme les **Exécutables**) sont bloqués quel que soit le bucket source pour empêcher l'entrée de logiciels malveillants.

Implémentation

Un groupe EntraID est créé pour contenir tous les utilisateurs qui doivent accéder aux ressources GCP au sein des organisations autorisées: `GDAR_APL_GCP_Enterprise-Users_P` . Ce groupe est ensuite ajouté au profil de filtrage URL Palo Alto pour injecter l'en-tête `X-Goog-Allowed-Resources` pour ces utilisateurs spécifiques.

!!! warning "Avertissement"

```
Utilisateur bénéficiant d'une dérogation: Il s'agit d'un troisième type d'utilisateur qui est
supporté **mais qui est en phase de décommissionnement**.
Ces utilisateurs font partis de groupes EntraID (**GOP_SE_Firewall_File-sharing_Global** et **
GOP_SE_Firewall_ArtificialIntelligence_Global**) qui permettent l'exclusion de l'application d
es règles DLP suivantes:
- DLP-ArtificialIntelligence_Global_Deny
- DLP-FileSharing-Deny
- DLP-FileSharing-QUIC-UDP
```

Type d'utilisateur	**Membre du groupe EntraID `GDAR_APL_GCP_Enterprise-Users_P` ?**	**Action technique (Palo Alto)**	**Résultat d'accès (Ressources corporatives)**
Utilisateur autorisé	**OUI**	**Injecte l'en-tête** de restriction (`X-Goog-Allowed-Resources`) contenant les iDs d'organisations autorisées.	**ACCÈS AUTORISÉ** *(L'accès est permis vers les ressources des organisations GCP corporatives mais interdit vers les ressources des organisations GCP non corporatives)*
Utilisateur standard	**NON**	**N'injecte pas** l'en-tête.	**ACCÈS BLOQUÉ** *(Bloqué par les règles de sécurité DLP par défaut)*

Dernière modification de cette page le 3/10/2026 6:42:16 PM +00:00 (UTC).